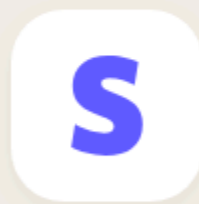


BEFORE YOU LAUNCH

~5,000

**AI-built apps found  
leaking data**



4 checks to run on yours first →



@shazimbuides

## WHAT HAPPENED

# One scan. 5,000 leaks.

April: an access flaw hit apps built on Lovable. May: a scan of AI-built apps found thousands leaking.

**380,000** apps scanned

**~5,000** exposing sensitive data

## BUILT ON



Lovable



Replit

Base44 &amp; others



@shazimbuidls

## CHECK 1

# Swap the ID in the URL

Log in as one user, then change the ID in the address bar to another user's.

## YOU'LL USE



Your browser

2 test accounts

 id swap · in your browser

TRY



log in as A, change the ID in the URL

FAIL



user B's data loads — stop here

FIX



check who owns each record, server-side

PASS



you get “access denied”

Try: `/invoices/1042` → `/invoices/1043`



## CHECK 2

# Hide your secret keys

Search the code that runs in the browser for secret keys. Publishable keys are fine.

## YOU'LL USE

 Your code Stripe keys Supabase keys secret scan · in your code

TRY



search the browser bundle for keys

FAIL



a secret key shows up

FIX



move it to the server, then rotate it

PASS



only publishable keys left

```
$ grep -rE "sk_live_|service_role" ./dist
```



## CHECK 3

# Lock every table

On Supabase, turn on row level security for every table – then test it with a second account.

## YOU'LL USE

 Supabase

2nd test account

 table rules · in supabase

TRY



open each table's RLS setting

FAIL



a table says "RLS disabled"

FIX



enable RLS, add a policy per table

PASS



user 2 can't see user 1's rows

SQL: `alter table messages enable row level security;`



@shazimbuides

## CHECK 4

# Break your own checkout

In test mode, double-click pay and drop your connection mid-payment.

## YOU'LL USE

 Stripe test mode

your checkout

 payment test · in test mode

TRY

 S

double-click pay, kill the connection

FAIL

 S

two charges for one order

FIX

 S

an idempotency key on every payment

PASS

 S

one charge, every time

Test card: 4242 4242 4242 4242 · any future date · any CVC



@shazimbuides

**BONUS**

# Restore a backup — once

Before you ever need it. A backup you've never restored is a hope, not a backup.

**YOU'LL USE****Supabase backups****a test project**

● ● ● restore drill · in a test project

**TRY****restore into a test project****FAIL****it errors, or data's missing****FIX****fix backups before you need them****PASS****the app runs on the restored copy**

## WHY IT COSTS MORE

# \$5K build vs \$15K build

These checks are most of what the extra money buys.

|                           | \$5K                     | \$15K                               |
|---------------------------|--------------------------|-------------------------------------|
| Access checks             | <input type="checkbox"/> | <input checked="" type="checkbox"/> |
| No secrets in the browser | <input type="checkbox"/> | <input checked="" type="checkbox"/> |
| Database rules            | <input type="checkbox"/> | <input checked="" type="checkbox"/> |
| Safe payments             | <input type="checkbox"/> | <input checked="" type="checkbox"/> |
| Tested backups            | <input type="checkbox"/> | <input checked="" type="checkbox"/> |



# Not sure what yours would show?



Send me a message and I'll tell you where I'd  
look first.

**DM @shazimbuid**



@shazimbuid